



SafeNode Secure Development and Release Runbook

Developer controls for changes, testing, review, signing, and production promotion.

Document version: 2026-07-27

Product: Safenode

Classification: Internal / customer-safe where noted

Repository rules

- Never commit real environment files, provider tokens, private keys, vault data, or recovery material.
- Use feature branches and pull requests; do not force-push protected branches.
- Keep security-sensitive changes narrow and add tests before merge.
- Treat generated build output as disposable; source and lockfiles are authoritative.
- Do not resolve unexplained filesystem or Git artifacts by destructive reset commands.

Required verification

Area	Command or check	Gate
Frontend unit tests	<code>npm run test -- --run</code>	All tests pass
Frontend type/build	<code>npm run type-check</code> ; <code>npm run build</code>	No new errors; production build succeeds
Backend type-check	<code>npm run type-check</code>	Clean
Backend tests	<code>npm test -- --runInBand</code>	All tests pass against test DB
Rust desktop	<code>cargo fmt --check</code> ; <code>cargo check</code>	Clean
Security	<code>npm audit --omit=dev --audit-level=high</code>	Review and resolve high/critical findings
Deploy	Railway health + Pages canonical URL	Both healthy

WebAuthn and passkey release tests

- Register a passkey on localhost and the production origin separately.
- Verify origin and RP ID configuration for web, Android, iOS, and desktop.
- Unlock the vault with PRF where supported.
- Verify password and recovery-kit fallback.
- Confirm no master password, raw vault key, recovery secret, or PRF output appears in localStorage, sessionStorage, IndexedDB, logs, or network payloads.
- Test device removal, re-approval, and multi-device behavior.

Billing release tests

- Verify Annual is the default selection.
- Toggle Monthly and inspect the selected price/checkout before payment.
- Confirm each Personal, Family, and Teams monthly/annual Paddle price ID maps correctly.
- Verify trial configuration in Paddle itself; trial duration is provider price configuration, not frontend copy.
- Send a signed sandbox webhook and verify tier/status/period dates and idempotent replay handling.
- Confirm cancellation and past-due events downgrade or restrict access as designed.

Native release controls

- Android: stable signing certificate, Credential Manager/WebAuthn, Digital Asset Links, HTTPS API origin.
- iOS: associated domains, App ID entitlements, AASA file, native passkey bridge.

- Desktop: PKCE/deep-link callback, single-instance routing, Windows Authenticode, Linux checksums/signatures, macOS signing/notarization.
- Do not enable download links until the artifact and association verification gates pass.

Release record

Every release should record: merge commit, tag, CI run, dependency/audit result, database schema state, deployment IDs, smoke-test evidence, rollback target, and approver.